Tag 2

13:30-15:00

15:30-17:00

KI-Compliance

gollnickdata.de

Agenda: KI-Compliance

Ziel: rechtliche Grundlagen und Risikoverständnis kennen

Tag 2

01
Rechtliches Rahmenwerk in der EU

02
Der EU AI-Act

03
Anwendbarkeit des EU AI-Act

04
Compliance mit dem EU AI-Act

05
EU AI-Act in der Praxis

06
Ausblick und aktuelle Neuerungen

Tag 3: Rechtliche *Compliance by design* in der KI Projektarbeit

RAHMENWERK VOR DEM EU AI-ACT

EU- Rechtsrahmen

Sektorale Vorschrif-ten

Vorschriften für die digitale Wirtschaft

Generelle Rechtsvorschriften

Chip Gesetz

Daten-Gesetz (Data Act)

Gesetz über digitale Dienste (Digital Service Act- DSA)

Rechtsakt zur Cybersicherheit (EU-NIS-2)

Datenschutzrichtlinie zur elektr. Kommunikation (ePrivacy-Richtlinie)

Gesetz über digitale Märkte (Digital Markets Act- DMA)

Daten Governance Rechtsakt (Data Governance Act- DGA)

Produkthaftung

DSGVO

z.B. Ge-sundheits-wesen, Finanz-wesen, Automobil industrie

Anmerkung: Über die oben genannten Gesetze hinaus, können weitere Gesetze relevant sein, wie z.B. das Gesetz gegen den unlauteren Wettbewerb (UWG) oder das Telemediengesetz (TMG)

Exercise 1

1. Offene Diskussion:
    1. Mit welchen Regularien hattet Ihr bereits zu tun?
    2. Welche sind maßgeblich für Euch?

10 min Plenum

RAHMENWERK VOR DEM EU AI-ACT

EU- Rechtsrahmen

Sektorale Vorschrif-ten

Vorschriften für die digitale Wirtschaft

Generelle Rechtsvorschriften

Chip Gesetz

Daten-Gesetz (Data Act)

DSA

Rechtsakt zur Cybersicherheit (EU-NIS-2)

Datenschutzrichtlinie zur elektr. Kommunikation (ePrivacy-Richtlinie)

DMA

Daten Governance Rechtsakt (Data Governance Act-DGA)

Produkthaftung

DSGVO

z.B. Ge-sundheits-wesen, Finanz-wesen, Automobil industrie

RAHMENWERK VOR DEM EU AI-ACT

EU- Rechtsrahmen

Sektorale Vorschrif-ten

Vorschriften für die digitale Wirtschaft

Generelle Rechtsvorschriften

Chip Gesetz

Daten-Gesetz (Data Act)

Gesetz über digitale Dienste (Digital Service Act- DSA)

Rechtsakt zur Cybersicherheit (EU-NIS-2)

Datenschutzrichtlinie zur elektr. Kommunikation (ePrivacy-Richtlinie)

Gesetz über digitale Märkte (Digital Markets Act- DMA)

Daten Governance Rechtsakt (Data Governance Act- DGA)

Produkthaftung

DSGVO

z.B. Ge-sundheits-wesen

RAHMENWERK VOR DEM EU AI-ACT

EU Rechtsrahmen: Datenschutz Grundverordnung (DSGVO)

Ziel

Die DSGVO schützt die Grundrechte und Grundfreiheiten **natürlicher Personen** und insbesondere deren Recht auf Schutz personenbezogener Daten.

Transparenz

- Die DSGVO fordert eine klare Information und Zustimmung der betroffenen Personen bei der Datenerhebung und -verarbeitung.

Rechte Betroffener (personenbezogene Daten)

- Auskunft über verarbeitete Daten erhalten
- unrichtige oder nicht mehr erforderliche Daten korrigieren bzw. löschen zu lassen

DSGVO und KI

Was fordert DSGVO?
Bewusste Entscheidungen und Aktives Management

→ DSGVO = Baseline

→ Gute DSGVO-Strukturen bedeutet weniger Reibung bei AI Compliance

→ z.B. Standard-PIA und AI Ethics Assessment bei jedem neuen Use Cases

Personenbezug

Bezieht sich die KI auf identifizierbare (natürliche) Personen?

Beispiele: Kundendaten, Mitarbeiterdaten (Sales), Briefe/Mails/DOcs

Zweck und Rechtsgrundlage

Warum dürfen wir diese Daten für KI nutzen?

Typisch: Vertrag, Gesetz, Einwilligung, berechtigtes Interesse (wesentl. Verarb.)

Transparenz und Kontrolle

Können wir erklären, was die KI tut?

DSGVO fordert: Transparenz, Auskunft, Korrektur, Löschung für den Nutzer

Schutz und Verantwortung

Sind Daten und Ergebnisse angemessen geschützt?

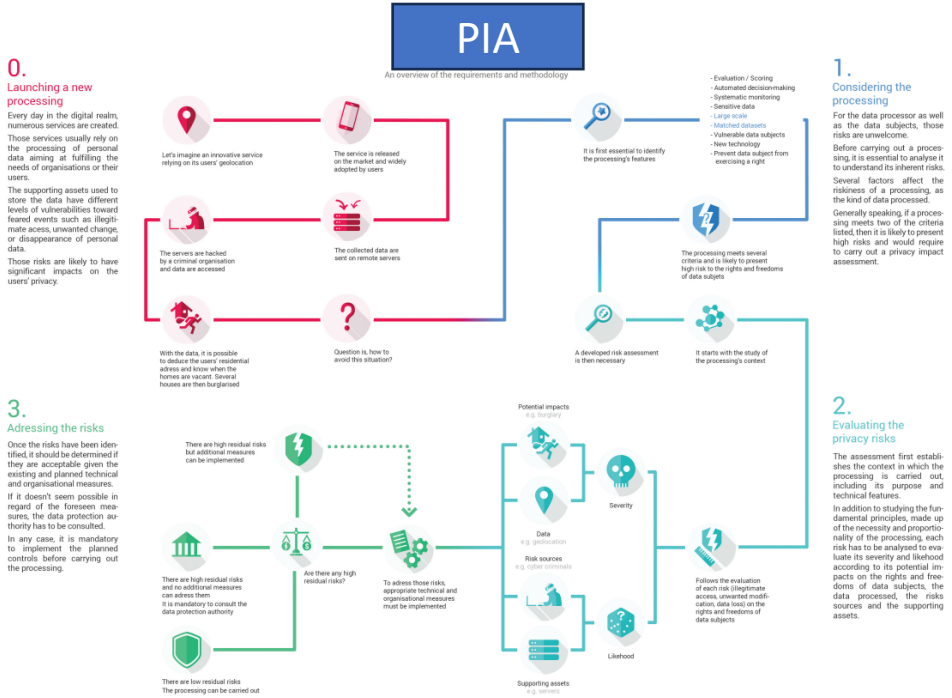
Themen: Sicherheitsmaßnahmen, Zugriff, Speicherung, Minimierung, Weitergabe, Anbieter/ Cloud

RAHMENWERK VOR DEM EU AI-ACT

Datenschutz und Künstliche Intelligenz (KI) - Praxistipps

Datenschutz-Folgenabschätzung (DSFA, bzw. **Data Protection Risk Assessment DPRA** und **PIA - Privacy Impact Assessment):**

systematische Analyse der Auswirkungen einer Datenverarbeitung auf die **Privatsphäre** und die **Grundrechte und -freiheiten**



https://www.cnil.fr/sites/default/files/atoms/files/171019_fiche_risque_en_cmjk.pdf

RAHMENWERK VOR DEM EU AI-ACT

Datenschutz und Künstliche Intelligenz (KI) - Praxistipps

Data Protection Risk Assessment (DPRA) &
Data Protection Impact Assesment (DPIA)

It should be noted that the evaluation of the security of the processing is a subset of the data protection impact assessment:

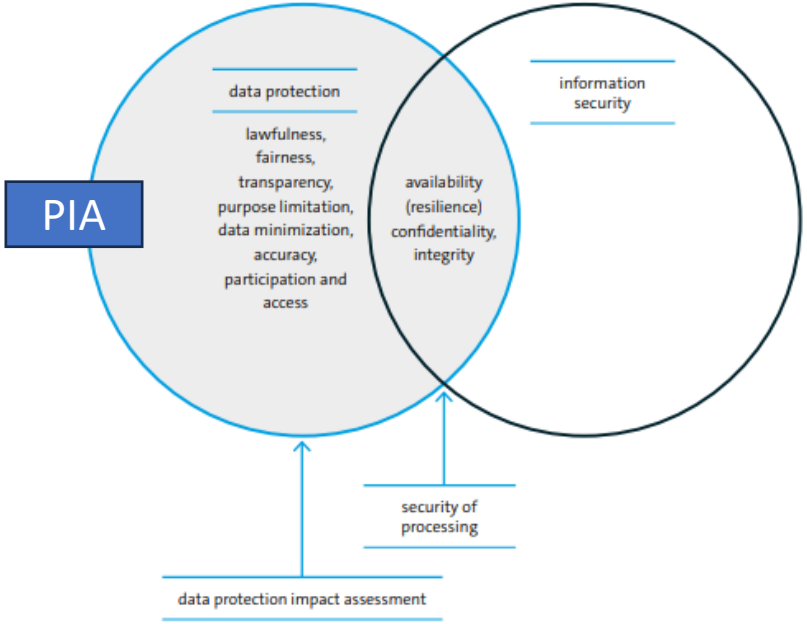


fig. 1: Overlap Data Protection and Information Security

https://www.tcd.ie/dataprotection/assets/docs/7.11.3_20220926_draft_REAMS_DP_Data_Protection_Risk_Assessment_(%E2%80%98DPRA%E2%80%99).pdf
https://www.bitkom.org/sites/main/files/file/import/170919-lf-risk-assessment-eng-online-final.pdf
DSGVO & KI_ DPRA und DPIA.docx

RAHMENWERK VOR DEM EU AI-ACT

EU Rechtsrahmen: Fazit zum regulatorischen Flickenteppich

In Deutschland gab und gibt es nach wie vor **ungeklärte Fragen zur Haftung** und **Regulierung** von KI-Systemen. Es herrscht(e) **rechtliche Unsicherheit** in Bezug auf die **KI-Haftung**, die **Anwendbarkeit** des **Datenschutzrechts**, des **Urheberrechts** und des **Wettbewerbsrechts** sowie spezifische Regulierungen für bestimmte KI-Anwendungsfälle.

Dieser regulatorische **Flickenteppich** schuf vor dem EU AI Act ein komplexes Rechtssystem für KI-Entwickler und -Nutzer, mit fragmentierten Regeln, die nicht speziell für KI-Technologien konzipiert waren. **Das EU-KI-Gesetz zielt darauf ab, diese Lücken mit einem umfassenden, harmonisierten Ansatz zu schließen.**

EU-AI-Act

gollnickdata.de

EU AI-Act:

Sinn und Zweck

EU AI ACT

Das KI-Gesetz der Europäischen Union

Das Ziel des **AI Acts** besteht darin, die **Funktionsweise des europäischen Binnenmarktes zu verbessern** und die **Einführung von menschenzentrierter und vertrauenswürdiger künstlicher Intelligenz** (KI) zu fördern, während gleichzeitig ein hohes Schutzniveau für **Gesundheit, Sicherheit und** die in der Charta der Grundrechte verankerten **Grundrechte** – einschließlich Demokratie, Rechtsstaatlichkeit und Umweltschutz – gegenüber möglicher schädlicher Auswirkungen von KI-Systemen gewährleistet wird.

RAHMENWERK MIT DEM EU AI-ACT

EU- Rechtsrahmen

KI Spezifische VO

Vorschriften für die digitale Wirtschaft

Generelle Rechtsvorschriften

EU AI- ACT

Chip Gesetz

Daten-Gesetz (Data Act)

Gesetz über digita Dienste (Digital Service Act- DSA)

Rechtsakt zur Cybersicherheit

Datenschutzrichtlinie zur elektr. Kommunikation (ePrivacy-Richtlinie)

Gesetz über digitale Märkte (Digital Markets Act- DMA)

Daten Governance Rechtsakt (Data Governance Act- DGA)

Produkthaftung

DSGVO

z.B. Ge-sundheits-wesen

EU AI ACT

Europäische Werte und Ziele

Einheitliche Regeln für KI in der EU

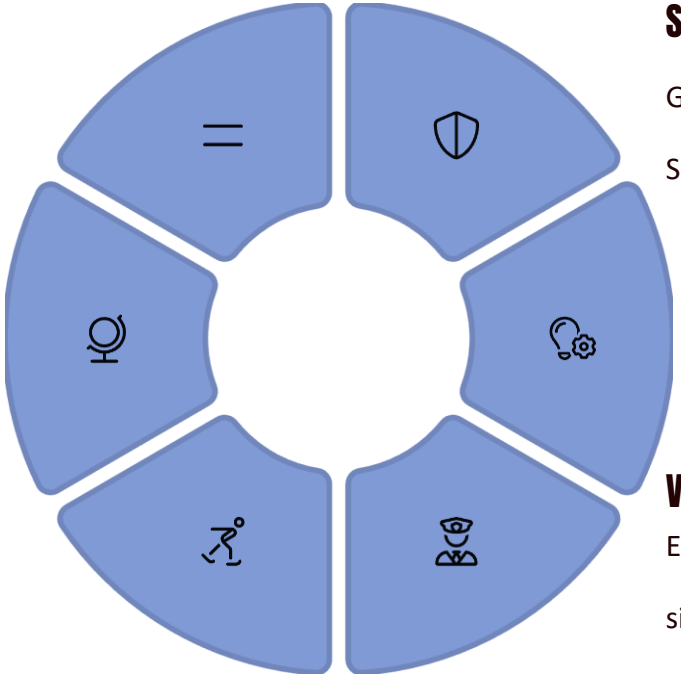
Schaffung harmonisierter Regeln für die Entwicklung, Vermarktung und Nutzung von KI in der EU

LEVEL PLAYING FIELD

Schaffung gleicher Bedingungen für alle Unternehmen, ob aus Europa oder aus dem Land der Big Tech

Risikobasierter Ansatz

Kategorisierung von KI nach Risikograd mit Verboten und Qualitätssicherung



Schutz der Bürger

Gewährleistung von Gesundheit, Sicherheit und Schutz der Grundrechte

Förderung von Innovation

Unterstützung von KI-Innovationen in Europa

Vertrauenswürdige und ethische KI

Etablierung der EU als Vorreiter bei sicherer und vertrauenswürdiger KI ("Brüssel-Effekt")

EU AI ACT

Das KI-Gesetz der Europäischen Union

Zwischen freiem Wettbewerb und Hochrisiko

Soll die europäischen Verbraucher vor Grundrechtsverletzungen **schützen**, indem:

- **Anbieter** von als hochriskant **eingestuften** KI-Systemen künftig die **Einhaltung** zahlreicher Anforderungen im Sinne der Grundsätze vertrauenswürdiger KI überprüfen und förmlich bestätigen – von **KI-Governance** bis zu **KI-Qualität**.

Trotz umfangreicher Grundsätze, Regeln und Verfahren sowie neuer Aufsichtsstrukturen soll das Gesetz **Innovationen in der EU nicht ausbremsen**, sondern die Weiterentwicklung im KI-Bereich, insbesondere durch Start-ups und KMUs, durch Rechtssicherheit und regulatorische Sandboxes **fördern**.

Quelle: https://www.faz.net/aktuell/wirtschaft/unternehmen/ki-regulierung-zwischen-freiem-wettbewerb-und-hochrisiko-110762737.html

EU AI-Act:

Zielgruppe (Rolle)

EU AI ACT

Zielgruppe (Artikel 2 KI-Verordnung)

Die Vorschriften gelten für alle **Unternehmen**, **Behörden**, **Organisationen** und **weitere Akteure**, die ein **KI-System** in der **EU einsetzen** oder auf den **Markt** bringen. Entscheidend ist dabei nicht zwingend der Standort des Unternehmens, sondern ob das KI-System in der Union **in Verkehr** gebracht oder in **Betrieb** genommen wird, oder ob dessen Ausgaben Auswirkungen auf Menschen in der EU hat.

EU AI ACT

Bin ich ein Regulierungsadressat?

- Anbieter: Marktortprinzip (Inverkehrbringen/ Betrieb in EU)
- Betreiber: Territorialitätsprinzip (Sitz/Aufenthalt in EU)
- Drittland- Akteure: Ergebnis wird in der Union verwendet

Anbieter und Hersteller

- entwickeln bzw. lassen ein KI-System/GPAI-Modell entwickeln
- bringen dieses unter dem eigenen Namen oder der eigenen Handelsmarke auf den Markt
- oder setzen es ein

Betreiber

- haben ihren Sitz in der EU
- nutzen oder integrieren KI-Systeme in ihre Arbeitsprozesse

Einführer (Importeur)

- haben ihren Sitz in der EU
- bringen KI-Systeme von Anbietern aus Drittländern auf den EU-Markt
- die eingeführten KI-Systeme haben Namen oder Handelsmarke des Unternehmens im Drittland

Händler

- bieten KI-Systeme auf dem EU-Markt an

Bevollmächtigter

- haben ihren Sitz in der EU
- sind von Anbieter eines KI-Systems/GPAI-Modells in einem Drittstatt schriftlich bevollmächtigt, in seinen Namen die EU-Vorschriften einzuhalten

EU AI ACT

Rolle & KI- System

KI System Anbieter

- natürliche oder juristische Person, Behörde, Einrichtung oder sonstige Stelle,
- die ein KI-System entwickelt oder entwickeln lässt und
- dieses unter ihrem eigenen Namen oder
- ihrer eigenen Marke in Verkehr bringt oder in Betrieb nimmt

Beispiele:

Start-up, das ein KI-gestütztes HR-Tool entwickelt und verkauft

Unternehmen, das eine externe Agentur beauftragt, ein KI-System zu bauen, es aber unter **eigener Marke** anbietet

Forschungslabor, das ein System zur öffentlichen Nutzung bereitstellt.

EU AI ACT

Rolle & KI- System

KI System Betreiber

Eine natürliche oder juristische Person,
- die ein KI System
- für den vorgesehenen Zweck verwendet
- Ohne dessen Kernfunktion zu verändern (Artikel 3 (4))

Hinweis:
- Rollen betreffen nur geschäftsmäßige Nutzung
- Private Nutzung ist davon nicht betroffen

EU AI ACT

Bin ich ein Regulierungsadressat?

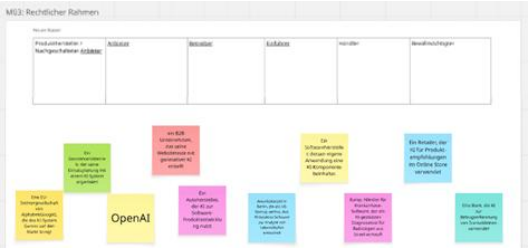
- Rollen (Adressaten)
  - Anbieter (Entwickeln oder entwickeln lassen)
  - Betreiber (in eigener Verantwortung verwendet)
  - Einführer (Sitz in EU, bringt Drittlands- KI in Verkehr)
  - Händler (Bereitstellung auf Unionsmarkt)
  - Bevollmächtigter des Anbieters (Drittland)
- Anbieter- Upgrade (Art. 25)
  - Anbringen eigener Name/Handelsmarke
  - Wesentliche Veränderung
  - Änderung der Zweckbestimmung (wird zu Hochrisiko- KI)

Exercise 2

1. Betrifft der EU AI Act diese Unternehmen / KI-Anwendungen?
2. In welcher Rolle?

3 min Individuell 1 Use Case schnappen

10 min Plenum



gollnickdata.de

Fazit zu Rollen bei Hochrisiko-Systemen

Ein **Betreiber** kann über Nacht zum **Anbieter** werden (mit allen teuren Pflichten für Hochrisiko-Systeme), wenn er:

1. Sein Logo auf die KI eines anderen klebt (**Rebranding**).
2. Die KI für einen Zweck nutzt, den der ursprüngliche Hersteller nicht vorgesehen hat (**Zweckänderung**).
3. Den Code oder das Modell wesentlich verändert (**Substantial Modification**).

Beispiel: Rollen entlang der Wertschöpfung

Stellen wir uns ein KI-gestütztes Diagnosetool für Radiologen vor (Medizinprodukt = Hochrisiko):

1. **Anbieter:** Ein Startup in Tel Aviv (Israel).
2. **Bevollmächtigter:** Eine Compliance-Agentur in Paris (vertritt das Startup gegenüber der EU).
3. **Importeur:** Eine Medizintechnik-Firma in Hamburg, die die Software erstmals in die EU einführt. → Achtung: Labeled die Firma die Software um = Anbieter!
4. **Händler:** Ein spezialisierter Fachhandel für Praxisbedarf, der die Software an die Krankenhäuser verkauft.
5. **Betreiber (Deployer):** Das Krankenhaus bzw. der Radiologe, der die Software am Patienten nutzt.

AUSNAHMEN

Wen der EU AI Act betrifft

Der AI Act sieht vor, dass die Verordnung ausschließlich für Anwendungsfälle gilt, die in den **Anwendungsbereich des EU-Rechts** fallen. Zuständigkeiten von Mitgliedsstaaten oder Regierungsbehörden in Bezug auf die nationale Sicherheit sollen in keiner Weise beschnitten werden.

Palantir: Poseck sieht Polizei durch System gestärkt

02.09.2024, 15:46 Uhr

https://www.fr.de/rhein-main/landespolitik/palantir-poseck-sieht-polizei-durch-system-gestaerkt-93276554.html

AUSNAHMEN

Wen der EU AI Act betrifft

Der AI Act sieht vor, dass die Verordnung ausschließlich für Anwendungsfälle gilt, die in den **Anwendungsbereich des EU-Rechts** fallen. Zuständigkeiten von Mitgliedsstaaten oder Regierungsbehörden in Bezug auf die nationale Sicherheit sollen in keiner Weise beschnitten werden.
Ausgenommen sind zudem **KI-Systeme, die ausschließlich militärischen oder verteidigungspolitischen Zwecken dienen** oder nur für **Forschung und Innovation** verwendet werden, auf **Open-Source-Lizenzen basieren** sowie die Nutzung für rein private Zwecke.

https://helsing.ai/de

EU AI ACT

Zeitplan der Verordnung

01.08.2024	02.02.2025	02.08.2025	02.08.2026	02.08.2027
Inkrafttreten	▪ Verbotene KI-Praktiken ▪ KI-Kompetenz	▪ General Purpose AI ▪ Governance ▪ Straftaten	▪ Hochrisiko-Systeme (Anhang III) ▪ KI-Systeme mit geringerem und min. Risiko ▪ KI-Reallabore	▪ Hochrisiko-Systeme (Anhang I)

Anwendbarkeit des EU AI- Acts

gollnickdata.de

Anwendbarkeit: was ist überhaupt “KI”?

„KI-System“ ein maschinengestütztes System, das für einen in unterschiedlichem Grade **autonomen** Betrieb ausgelegt ist und das nach seiner Betriebsaufnahme **anpassungsfähig** sein kann und das aus den erhaltenen Eingaben für explizite oder implizite Ziele **ableitet** („inferred“), wie Ausgaben wie etwa Vorhersagen, Inhalte, Empfehlungen oder Entscheidungen erstellt werden, die physische oder virtuelle Umgebungen beeinflussen können.
EU-AI Act, Artikel 3.1

Typische KI-Systeme

Zeit-Check 15:00? Pause

Technologie / Methode	Einstufung	Begründung & Beleg (AI Act)
Machine Learning (Deep Learning / Reinforcement Learning)	**Eindeutig KI**	Nutzt Daten, um Modelle zu erstellen, die Vorhersagen oder Entscheidungen **ableiten (Inferred)**.
GPAI-Modelle (General Purpose AI)	**KI-Modell**	Basismodelle (wie GPT-4), die für eine Vielzahl von Zwecken trainiert wurden. Sie sind die „Motoren“ für KI-Systeme (**Art. 3 Nr. 63**).
Logistische / Lineare Regression	**Grenzfall**	Nur KI, wenn sie Teil eines **komplexen Systems** ist, das Vorhersagen autonom ableitet. Reine Statistik ohne Automatisierung ist keine KI (**Erwägungsgrund 12**).
Regelbasierte Systeme (Expertensysteme)	**In der Regel NEIN**	Wenn Regeln **rein menschlich** definiert sind („If-Then“), **fehlt die maschinelle Inferenz**. Das ist klassische Software.
Klassische Dunkelverarbeitung	**NEIN**	Starre Prozessautomatisierung (z.B. automatische Rechnungsprüfung nach festen Betragsgrenzen) ist keine KI.
Smarte Suche / Filter	**NEIN**	Einfache Indexierung oder Sortierung nach festen Parametern (Preis aufsteigend) erfüllt nicht das Kriterium der Inferenz.

EINSTUFUNG GPAI-Modelle

GPAI-Modelle: Definition und Abgrenzung

Foundation-Modell
Ein großes, auf umfangreichen Daten vortrainiertes KI-Modell, das als vielseitige Grundlage für verschiedene Anwendungen dient.
Anpassbar für diverse Aufgaben (z.B. Text-, Bild-, Sprachverarbeitung).
Kein erneutes Grundlagentraining erforderlich.

Foundation Models sind meistens GPAI, auf Basis der EU AI Act Definition.

GPAI-Modell (erhebliche Auswirkungen)
„KI-Modell mit allgemeinem Verwendungszweck“
Ein im EU-KI-Gesetz definierter juristischer Begriff für ein KI-Modell, das:

- Eine erhebliche allgemeine Verwendbarkeit aufweist.
- Ein breites Spektrum an Aufgaben kompetent erfüllen kann.
- In eine Vielzahl nachgelagerter Systeme integrierbar ist.
- In der Regel mit großen Datenmengen trainiert wird (z.B. durch überwachtes, unüberwachtes, bestärkendes Lernen).

Indikator: Vermutung bei mehr als *einer Milliarde Parameter* (z.B. GPT-4, Midjourney v6).

1

Verhältnis & Unterscheidung

Der Begriff "Foundation Model" ist der gebräuchliche Ausdruck für das, was der EU AI Act als **"General-Purpose AI Model" (GPAI-Modell)** definiert. Die Gesetzgebung etablierte den letzteren zur spezifischen Regulierung dieser vielseitigen Modelle, die systemische Risiken bergen können.

2

Modell vs. System

Ein **GPAI-Modell** ist die abstrakte Repräsentation des gelernten Wissens (z.B. OpenAI GPT). Ein **GPAI-System** ist ein KI-System, das ein GPAI-Modell nutzt und selbst für mehrere Zwecke eingesetzt werden kann (z.B. ChatGPT).

EINSTUFUNG GPAI-Modelle

Zweistufiger Ansatz: GPAI- Modell mit systemischen Risiko

Level 1: KI-Modelle mit allgemeinem Verwendungszweck (GPAI)

Alle Modelle müssen zusätzliche **Transparenzpflichten** erfüllen. Dazu gehören neben technischer Dokumentation und detaillierten Aufstellungen über die Verwendung urheberrechtlich geschützter Trainingsdaten auch die Kennzeichnung von Inhalten, die mithilfe von KI generiert wurden, sowie Risikominderungsmaßnahmen.

Level 2: GPAI mit erheblichen Auswirkungen

Für „sehr leistungsstarke“ (hohe Auswirkungsfähigkeit) KI-Modelle, die **systemische Risiken** bergen können, gelten zusätzliche Pflichten, beispielsweise in Bezug auf die Überwachung schwerwiegender Vorfälle, die Modellbewertung und die Durchführung von Angriffstests.

GPAI-MODELL MIT SYSTEMISCHEM RISIKO

a) *Das GPAI-Modell weist Fähigkeiten mit **hohem Wirkungsgrad** auf (Art. 51 (1) a) KI-Verordnung). Oder*
b) *b) Es liegt eine entsprechende Entscheidung der Europäischen Kommission vor (Art. 51 (1) b) KI-Verordnung).*

Details zu a): Ein hoher Wirkungsgrad wird vermutet, wenn der kumulative Rechenaufwand für das Training mindestens 10^25 Gleitkommaoperationen (Floating Point Operations Per Second, kurz: FLOPs) benötigt.

Details zu b): Hierzu sind laut KI-Verordnung die Kriterien aus Anhang XIII zu berücksichtigen. Diese umfassen bspw. die **Anzahl der Modellparameter**, die **Größe** und **Qualität** des Datensatzes oder die **Anpassungsfähigkeit**. Für den Fall, dass ein GPAI-Modell die erste Bedingung erfüllt, unterliegt der **Anbieter** einer **unverzüglichen Mitteilungspflicht** (siehe Art. 52 KI-Verordnung) an die EU-Kommission.

GPAI-MODELL MIT SYSTEMISCHEM RISIKO

Für GPAI-Modelle mit systemischem Risiko gelten neben den **Informations-** und **Dokumentationspflichten** nach Art. 53 und Art. 54 zusätzliche Anforderungen nach Art. 55, wie:

- Erweiterung der technischen Dokumentation um die in Anhang XI Abschnitt 2 genannten Informationen,
- Evaluierung des GPAI-Modells zur Ermittlung und Minderung systemischer Risiken,
- Untersuchung und Bewertung der systemischen Risiken, sowie die Beobachtung und Dokumentation gravierender Vorfälle und deren Meldung an das KI-Büro, und
- Einführung von Maßnahmen zur Cybersicherheit sowie weitere Pflichten aus dem Art. 55 KI-Verordnung.

GPAI-MODELL MIT SYSTEMISCHEM RISIKO

Leitlinien und Praxisleitfäden

Für die Aufsicht über GPAI-Modelle ist das KI-Büro der Europäischen Kommission zuständig. Das KI-Büro hat Leitlinien und Praxisleitfäden zu GPAI-Modellen vor Geltungsbeginn im August 2025 veröffentlicht. Diese sind zwar nicht bindend, bieten aber einen wichtigen Einblick in die Interpretation und Auslegung der Regelungen aus Sicht der Europäischen Kommission.

https://artificialintelligenceact.eu/de/gpai-guidelines-overview/

Was gilt für Betreiber von GPAI?

Beispiel: Händler verwendet GPT von OpenAI als Customer Service Bot. Das Unternehmen hat ebenso Pflichten:

❌ Es ist **kein Anbieter** eines Foundation oder GPAI Models

✅ Es ist **Betreiber eines KI-Systems**

✅ Es trägt Verantwortung für den konkreten Einsatz

Zu den Betreiber-Pflichten eines GPAI gehört:

- Transparenzpflichten
- Risikobewertung
- menschliche Aufsicht
- Zweckdefinition

Referenz: https://eur-lex.europa.eu/legal-content/DE/TXT/?uri=CELEX:32024R1689#cpt_V

Risikoklassifizierung

EU AI ACT

Risikostufen

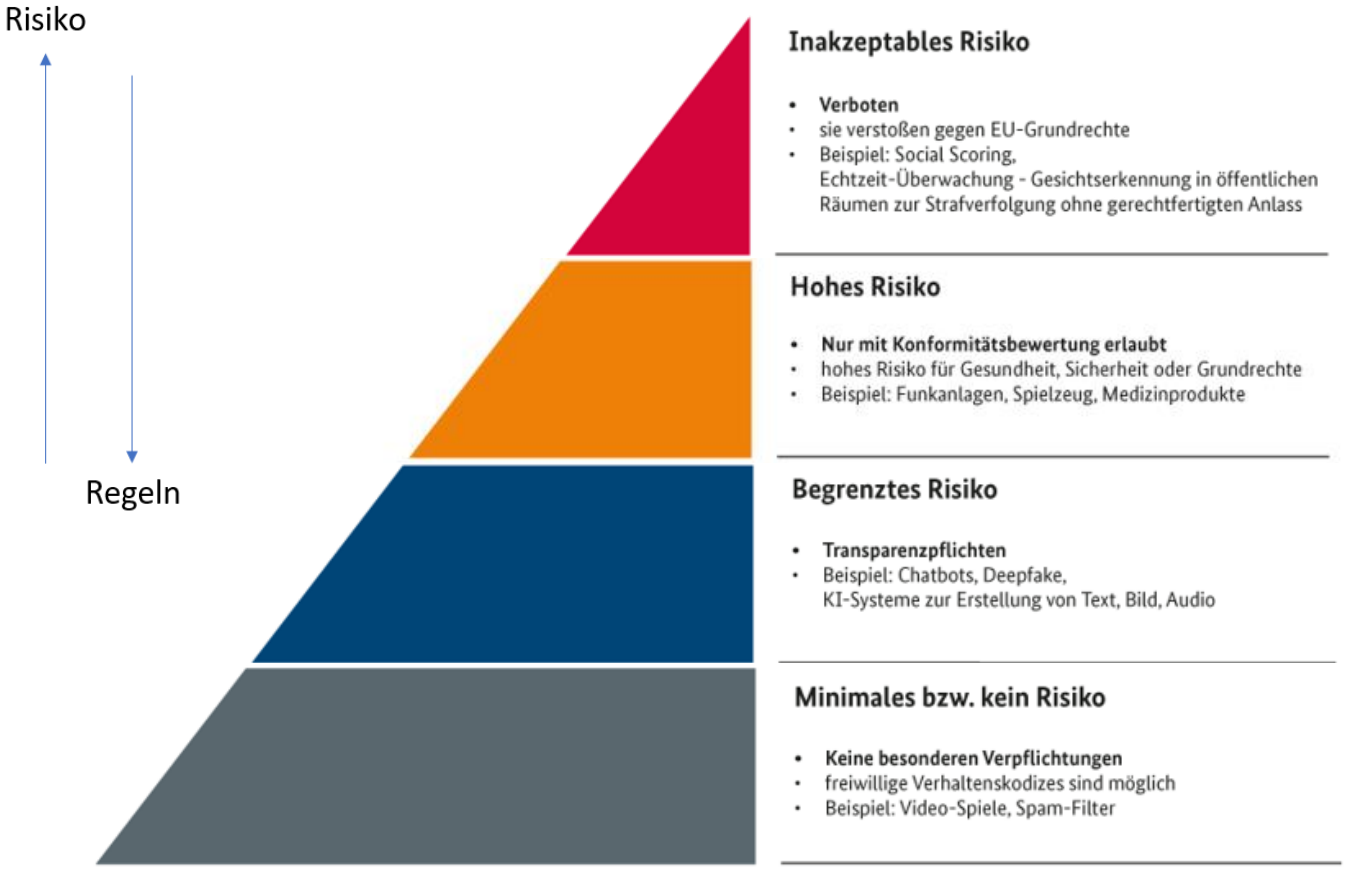
Die KI-Verordnung basiert auf einem risikobasierten Regulierungsansatz: Je höher das Risiko einer KI-Anwendung ist, desto strenger ist die Aufsicht.

Unter „Risiko“ versteht die KI-Verordnung eine Kombination aus zwei Faktoren:
Wie wahrscheinlich ist es, dass ein gewisser Schaden auftritt?
Und
Wie groß ist der Schaden?

EU AI ACT

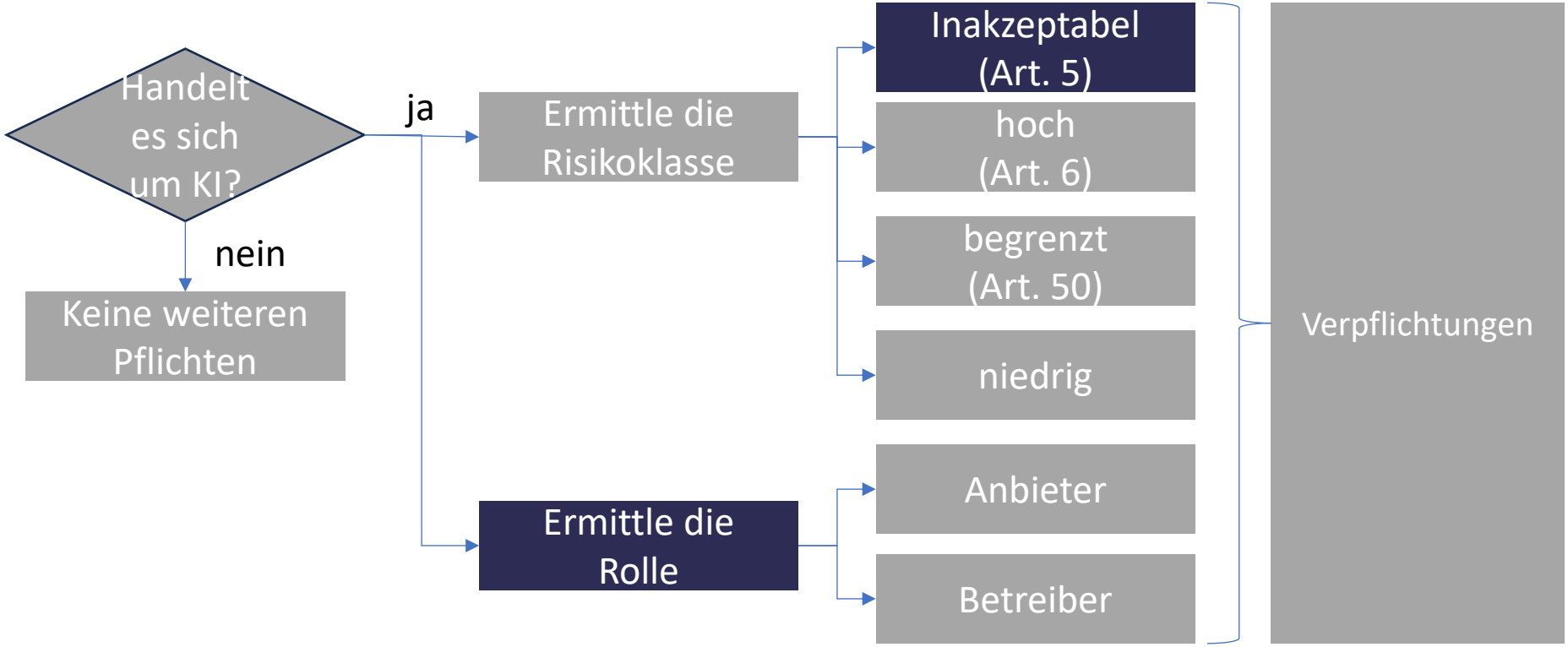
Risikostufen KI- Systeme

1. **Risikobasierter Ansatz**
2. Produktregulierungs ansatz (CE- Zeichen, Datenbank)
3. Horizontaler Ansatz (sektorübergreifend)



EU AI ACT

Risiko- und Rollenbetrachtung



8 VERBOTENE PRAKTIKEN

Die KI-Verordnung listet insgesamt acht verbotene Praktiken in Artikel 5 Absatz 1:

Artikel	Verbotene Praktik	Beispiele
5 (1)(a)	Schädliche Manipulation und Täuschung	• Chatbots, die Nutzern raten, sich selbst zu verletzen, terroristische Inhalte oder Anreize zu Gewalt fördern • KI-Systeme, die sich als andere Personen ausgeben, mit der Intention, die Fähigkeit von Personen, fundierte Entscheidungen über die Identität der Person zu treffen, erheblich beeinträchtigen
5(1)(b)	Schädliche Ausnutzung von Vulnerabilitäten	• Ein KI-gesteuertes Spielzeug, das mit Kindern interagiert und diese zu riskanten Handlungen ermutigt. Das kann wahrscheinlich zu körperlichen Schäden führen. • KI-Systeme, die ältere Menschen mit trügerischen Angeboten und Betrügereien ansprechen, um ihnen finanziellen Schaden zuzufügen
5(1)(c)	Soziale Bewertung	• Eine Sozialbehörde verwendet KI zur Berechnung einer Risikobewertung für die Betrugswahrscheinlichkeit von Empfängern von Haushaltsbeihilfen, wobei sie nicht mit der Person in Verbindung stehende Daten (z. B. Herkunft, Hautfarbe) verwendet

8 VERBOTENE PRAKTIKEN

Die KI-Verordnung listet insgesamt acht verbotene Praktiken in Artikel 5 Absatz 1:

5(1)(d)	Individuelle Risikobewertung und Vorhersage von Straftaten	• Polizei nutzt KI zur Vorhersage kriminellen Verhaltens (z. B. Aufstände oder Terrorismus) ausschließlich auf Grundlage individueller biometrischer Daten (z. B. besondere Gesichtszüge) ohne eine durch Menschen durchgeführte Bewertung anhand objektiver und überprüfbarer Tatsachen
5(1)(e)	Ungezieltes Auslesen von Gesichtsbildern	• Ein KI-gestütztes Web-Scraping-Tool zur wahllosen Extraktion von Gesichtsbildern aus verschiedenen Social-Media-Websites, um eine Gesichtsdatenbank mit mehreren Milliarden Bildern aufzubauen
5(1)(f)	Emotionserkennung an Arbeitsplätzen und in Bildungseinrichtungen	• Das Verwenden von Webcams und Spracherkennungssystemen durch Callcenter, um die Emotionen von Beschäftigten zu verfolgen (z. B. Ärger) • KI-System zur Überwachung der Aufmerksamkeit von Schülern und/oder Lehrern

8 VERBOTENE PRAKTIKEN

Die KI-Verordnung listet insgesamt acht verbotene Praktiken in Artikel 5 Absatz 1:

5(1)(g)	Biometrische Kategorisierung für "sensible" Merkmale	• Ein KI-System auf einer Social-Media-Plattform kategorisiert Personen anhand ihrer vermuteten sexuellen Orientierung anhand biometrischer Daten von Fotos, um ihnen personalisierte Werbung anzuzeigen.
5(1)(h)	Biometrische Echtzeit-Fernidentifizierung in öffentlich zugänglichen Räumen zu Strafverfolgungszwecken	• Mobile Überwachungskameras der Polizei in einer Einkaufsstraße, die mit KI-basierten Gesichtserkennungstechnologien ausgestattet sind, um gesuchte Personen zu identifizieren

EU AI ACT

Risikoklassen: inakzeptables Risiko – verbotene Praktiken (Artikel 5)

Aufgabe 4

Verbotene KI

KI-Systeme, die gegen Grundrechte verstoßen oder Menschen manipulieren, z. B.:

- **Soziale Bewertung (Social Scoring)** durch Behörden,
- **Manipulation des Verhaltens mit erheblichem Schaden** (z. B. Spielzeug mit Sprachsteuerung, das Kinder zu gefährlichem Verhalten verleitet),
- **Echtzeit-Überwachung im öffentlichen Raum** durch Gesichtserkennung (mit Ausnahmen, Predictive Policing).

Das neue KI-System **"SafetyAnywhere"** soll die Sicherheit an großen Veranstaltungsorten revolutionieren, indem es KI nutzt, um in Echtzeit **versteckte Waffen zu erkennen** sowie **Bedrohungen durch Gesichtserkennung und Verhaltensanalyse** zu identifizieren, und dadurch **potenzielle Straftaten zu vereiteln**. Es verspricht, Warteschlangen zu verkürzen, Veranstaltungen sicherer zu machen, die betriebliche Effizienz zu verbessern und sich mithilfe des maschinellen Lernens sogar im Laufe der Zeit anzupassen.

In der Rolle des Product Owner ist es Ihre Aufgabe, die Anforderungen an das System zu verstehen und zu priorisieren, die Ergebnisse zu dokumentieren und der Unternehmensleitung Empfehlungen vorzulegen: stimmt das vorgeschlagene System mit den Anforderungen des EU AI Acts überein?

EU AI ACT

Vereinfachte Checkliste: inakzeptables Risiko – verbotene Praktiken (Artikel 5)

Lösung

(1)(a) Nutzt das System unterschwellige Techniken, um Individuen zu manipulieren?

> ?

(1)(b) Nutzt das System Schwachstellen spezifischer Gruppen wie Kinder oder Menschen mit Behinderung aus, die zu Verhaltensweisen führen können, die physischen oder psychischen Schaden verursachen?

> ?

(1)(c) Beinhaltet das System soziale Bewertungen ("Social Scoring") durch öffentliche Stellen, die zu Benachteiligungen führen können?

> ?

(1)(d) Nutzt das System Risikobewertungen, um vorherzusagen, ob eine Person eine Straftat begehen wird, basierend auf Profiling oder der Bewertung von Persönlichkeitsmerkmalen?

> ?

(1)(f) Nutzt das System emotionale Erkennung in Arbeitsplätzen, Bildungseinrichtungen oder anderen sensiblen Kontexten?

> ?

(1)(h) Nutzt das System biometrische Echtzeit-Fernidentifizierung zu Strafverfolgungszwecken?

> ?

STRAFEN

Durchsetzung des EU-KI-Gesetzes: Geldbußen

Das **EU-KI-Gesetz sieht wirksame, verhältnismäßige und abschreckende Geldbußen für Verstöße vor.**

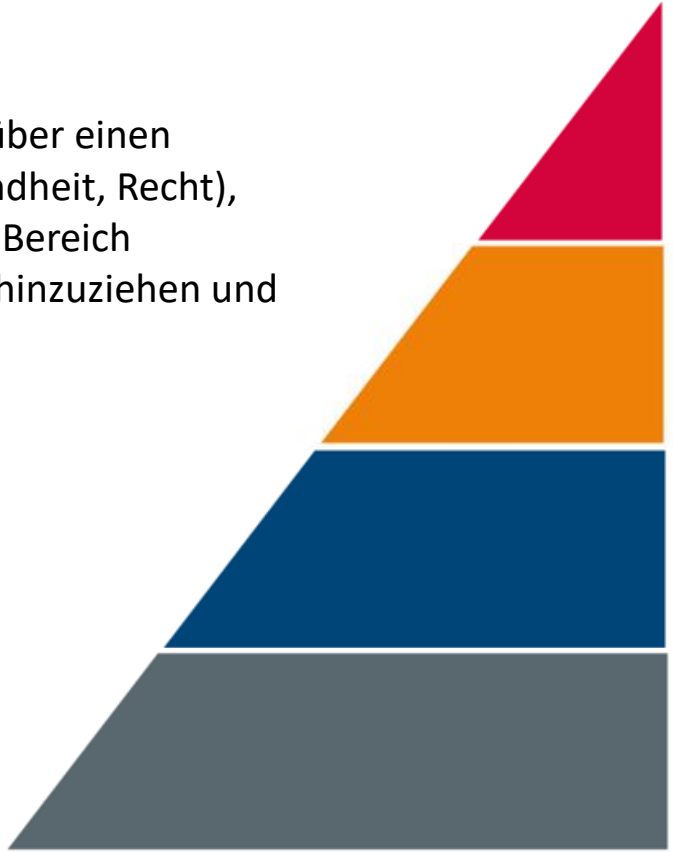
Art des Verstoßes	Höchststrafe (Geldbuße)
Verstöße gegen absolute Verbote	Bis zu **35 Millionen Euro** oder **7%** des weltweiten Jahresumsatzes.
Allgemeine Verstöße (gegen das EU-KI-Gesetz)	Bis zu **15 Millionen Euro** oder **3%** des Jahresumsatzes.
Falsche Informationen an Behörden	Bis zu **7,5 Millionen Euro** oder **1%** des Jahresumsatzes.

Die erheblichen Strafen für Verstöße gegen das EU-KI-Gesetz spiegeln die **Bedeutung** wider, die die EU der Sicherstellung der Einhaltung ihres KI-Regulierungsrahmens beimisst.

- insbesondere für **große Technologie-unternehmen abschreckend** wirken.
- in einem **angemessenen Verhältnis zur Schwere des Verstoßes**.
- **vergleichbar mit Strafen nach anderen EU-Digitalvorschriften** wie der **DSGVO** und dem **DSA**.

Hochrisiko-AI

Sobald die KI eine Entscheidung über einen Menschen trifft (Job, Geld, Gesundheit, Recht), sind Sie höchstwahrscheinlich im Bereich Hochrisiko → bestenfalls Anwalt hinzuziehen und eine Zertifizierung prüfen



Inakzeptables Risiko

- **Verboten**
- sie verstoßen gegen EU-Grundrechte
- Beispiel: Social Scoring,
  Echtzeit-Überwachung - Gesichtserkennung in öffentlichen Räumen zur Strafverfolgung ohne gerechtfertigten Anlass

Hohes Risiko

- **Nur mit Konformitätsbewertung erlaubt**
- hohes Risiko für Gesundheit, Sicherheit oder Grundrechte
- Beispiel: Funkanlagen, Spielzeug, Medizinprodukte

Begrenztes Risiko

- **Transparenzpflichten**
- Beispiel: Chatbots, Deepfake,
  KI-Systeme zur Erstellung von Text, Bild, Audio

Minimales bzw. kein Risiko

- **Keine besonderen Verpflichtungen**
- freiwillige Verhaltenskodizes sind möglich
- Beispiel: Video-Spiele, Spam-Filter

Hochrisiko abgrenzen

1. KI im Recruiting (Bewerber-Ranking)

- **Szenario:** Eine Software analysiert Lebensläufe oder Video-Interviews und erstellt ein Ranking der "besten" Kandidaten für eine Stelle.
- **Warum Hochrisiko?** Weil sie über den Zugang zum Arbeitsmarkt entscheidet. Ein Bias (Voreingenommenheit) im Algorithmus könnte ganze Bevölkerungsgruppen diskriminieren.

2. KI zur Kreditwürdigkeitsprüfung (Credit Scoring)

- **Szenario:** Eine Bank nutzt ein Modell, um automatisch zu entscheiden, ob eine Privatperson einen Kredit oder eine Kreditkarte erhält.
- **Warum Hochrisiko?** Der Zugang zu Finanzmitteln ist eine wesentliche Voraussetzung für die Teilhabe am gesellschaftlichen Leben (Wohnungskauf, Firmengründung).

3. KI in der medizinischen Diagnose

- **Szenario:** Ein Tool, das Hautbilder analysiert, um Anzeichen von Melanomen (Hautkrebs) zu erkennen und dem Arzt eine Diagnose-Empfehlung gibt.
- **Warum Hochrisiko?** Ein Fehler des Systems kann unmittelbar zu körperlichen Schäden oder zum Tod führen (Fehldiagnose)

Hochrisiko abgrenzen

4. KI zur Leistungsbewertung am Arbeitsplatz

- **Szenario:** Ein System, das die Produktivität von Lagermitarbeitern oder Softwareentwicklern misst und darauf basierend Vorschläge für Beförderungen oder Kündigungen macht.
- **Warum Hochrisiko?** Es greift tief in das Abhängigkeitsverhältnis zwischen Arbeitgeber und Arbeitnehmer ein und betrifft die Existenzgrundlage.

5. KI zur Identifizierung in der Strafverfolgung

- **Szenario:** Nachträgliche (nicht Echtzeit!) Gesichtserkennung in Videomaterial durch die Polizei, um Verdächtige in einer Menschenmenge zu finden.
- **Warum Hochrisiko?** Es berührt massiv das Recht auf Privatsphäre und die Bewegungsfreiheit in der Öffentlichkeit.

Exercise 3

1. In Breakouts:
    1. Kategorisiert die Use Cases in die Risikoklassen?
    2. Wo gibt es Diskussionsbedarf?
2. Vorstellung im Plenum

7 min Breakouts

8 min Plenum

Compliance mit dem EU AI-Act

gollnickdata.de

Grobe Compliance Einordnung

Verbot bestimmter KI-Praktiken

Artikel 5 verbietet unter anderem manipulative unterschwellige Techniken, soziale Bewertung (Social Scoring) und bestimmte biometrische Echtzeiterkennungssysteme.

Strenge Anforderungen für Hochrisiko-KI-Systeme

Diese unterliegen Pflichten u. a. zu Risikomanagement, Datenqualität, Transparenz, menschlicher Aufsicht und Konformitätsbewertung.

Fokus heute

Transparenzpflichten für Begrenztes Risiko

Kennzeichungspflicht.

Freiwillige Kodizes bei minimalem Risiko

Inakzeptables Risiko

- **Verboten**
- sie verstoßen gegen EU-Grundrechte
- Beispiel: Social Scoring, Echtzeit-Überwachung - Gesichtserkennung in öffentlichen Räumen zur Strafverfolgung ohne gerechtfertigten Anlass

Hohes Risiko

- **Nur mit Konformitätsbewertung erlaubt**
- hohes Risiko für Gesundheit, Sicherheit oder Grundrechte
- Beispiel: Funkanlagen, Spielzeug, Medizinprodukte

Begrenztes Risiko

- **Transparenzpflichten**
- Beispiel: Chatbots, Deepfake, KI-Systeme zur Erstellung von Text, Bild, Audio

Minimales bzw. kein Risiko

- **Keine besonderen Verpflichtungen**
- freiwillige Verhaltenskodizes sind möglich
- Beispiel: Video-Spiele, Spam-Filter

Compliance bei Begrenztem Risiko

EU AI ACT

Risikostufen KI- Systeme: Begrenztes Risiko -KI-Systeme

Inakzeptables Risiko

- **Verboten**
- sie verstoßen gegen EU-Grundrechte
- Beispiel: Social Scoring,
  Echtzeit-Überwachung - Gesichtserkennung in öffentlichen Räumen zur Strafverfolgung ohne gerechtfertigten Anlass

Hohes Risiko

- **Nur mit Konformitätsbewertung erlaubt**
- hohes Risiko für Gesundheit, Sicherheit oder Grundrechte
- Beispiel: Funkanlagen, Spielzeug, Medizinprodukte

Begrenztes Risiko

- **Transparenzpflichten**
- Beispiel: Chatbots, Deepfake,
  KI-Systeme zur Erstellung von Text, Bild, Audio

Minimales bzw. kein Risiko

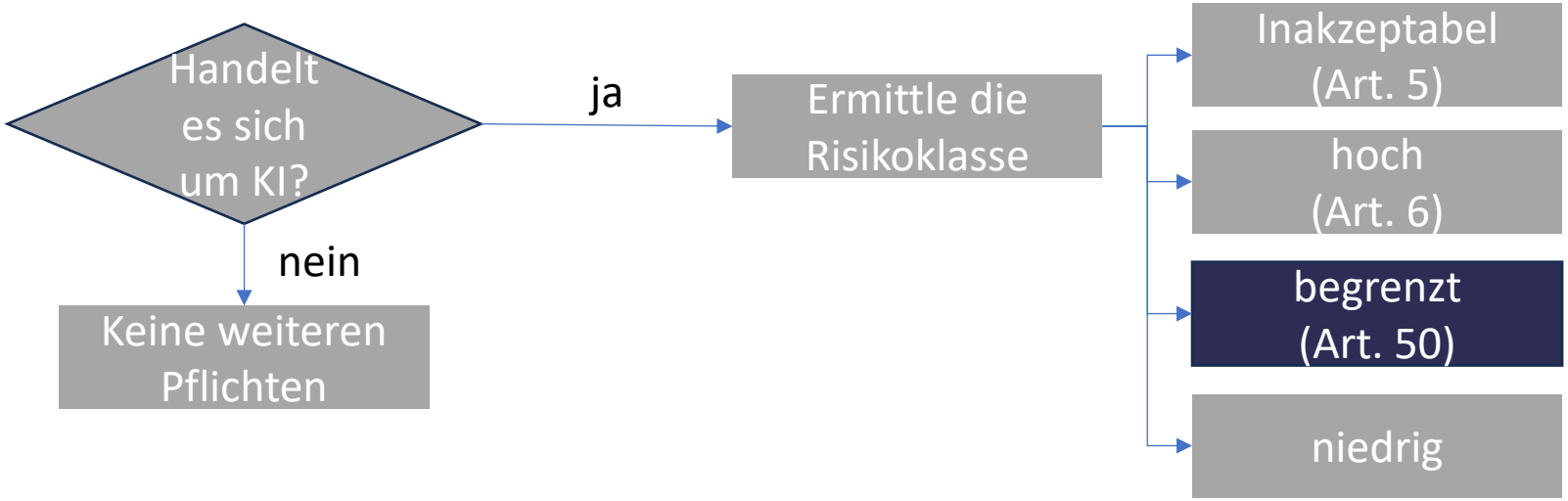
- **Keine besonderen Verpflichtungen**
- freiwillige Verhaltenskodizes sind möglich
- Beispiel: Video-Spiele, Spam-Filter

Transparenzpflichten für Begrenztes Risiko

Kennzeichungspflicht.

EU AI ACT

Risikoklasse: hoch



Begrenztes Risiko

Von den allermeisten KI-Anwendungen gehen keine besonderen Risiken aus. Dazu gehören beispielsweise E-Mail-Spamfilter oder Predictive-Maintenance-Systeme, personalisierte Produktvorschläge oder Chatbots in der Kundenkommunikation sowie Computerspiele, die KI einsetzen. Für diese Anwendungen gelten keine oder nur sehr geringe Anforderungen wie Transparenzvorgaben.

Dennoch gelten für KI-Systeme aller Risikoeinstufungen, die **mit Personen interagieren**, wie Chatbots oder Empfehlungssysteme, bestimmte **Transparenzpflichten**. Von einem KI-System generierte Inhalte wie Unterhaltungen (Chatbots), Deepfakes oder biometrische Kategorisierungen müssen gekennzeichnet werden. Diese Pflichten gehen mit der Einordnung in die Klasse **„begrenztes Risiko“** einher.

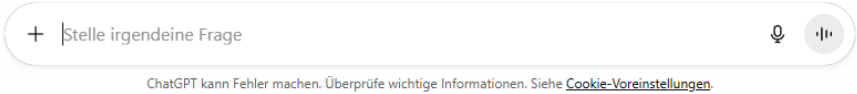
Begrenztes Risiko

Transparenzpflicht: Artikel 50

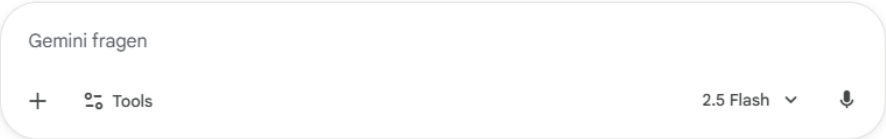
Die betreffenden natürlichen Personen sind darüber zu informieren, dass sie mit einem KI-System interagieren

Ausnahme:

- durch Umstände und Nutzungskontext offensichtlich, dass es sich um ein KI-System handelt
- Systeme, die gesetzlich zur Aufdeckung, Verhütung, Untersuchung oder Verfolgung von Straftaten zugelassen sind



ChatGPT kann Fehler machen. Überprüfe wichtige Informationen. Siehe Cookie-Voreinstellungen.



Begrenztes Risiko

Transparenzpflichten (Art. 50)

Anbieterpflichten

- Interaktion mit natürl. Personen (informieren, außer offensichtlich)
- Synthetische Inhalte (maschinenlesbare Kennzeichnung)

Betreiberpflichten

- Emotionserkennung/ biometrische Kategorisierung (informieren)
- Deepfakes (Offenlegung, außer künstlerisch/ satirisch)
- Texte zu öffentlichem Interesse (Offenlegung, außer menschliche Kontrolle)

Anbieter GPAI- Modelle (Art. 53)

- Technische Dokumentation (Anhang XI)
- Urheberrechsts- Compliance (Einhaltung TDM- Rechtsvorbehalt)
- Veröffentlichung Zusammenfassung Trainingsinhalte
- Benennung Bevollmächtigter (bei Drittland- Sitz)
- Zusatzpflichten bei systemischem Risiko (Art. 55)

Begrenztes Risiko

Aufbau KI- Kompetenz (Art. 4)

- Sicherstellung ausreichender KI- Kompetenz des Personals
- Berücksichtigung technischer Kenntnisse, Erfahrung, Ausbildung

➢ Deep Dive

Begrenztes Risiko - Strafen

Geringes Risiko: Bußgeld

Niedrigste Sanktionsstufe (Formelle Pflichten und falsche Informationen)

Verstoß:

- Verstöße gegen formelle oder verfahrenstechnische Pflichten der Anbieter oder Betreiber.
- Verletzungen der Transparenzpflichten für KI-Systeme mit begrenztem Risiko (Art. 50).
- Die Bereitstellung falscher, unvollständiger oder irreführender Informationen an die benannten notifizierten Stellen oder die zuständigen nationalen Behörden im Rahmen von Konformitätsbewertungen, Audits oder Untersuchungen.

Sanktion

- Niedrige Geldbußen, dienen aber der Einhaltung der nötigen Bürokratie, der Transparenz und der Kooperation mit den Aufsichtsbehörden

KI- Kompetenz (AI LITERACY)

KI KOMPETENZ

KI-Kompetenz Definition

KI-Kompetenz bezieht sich auf das **Wissen**, die **Fähigkeiten** und das **Verständnis**, das erforderlich ist, um **effektiv** mit **KI-Systemen** zu interagieren. Der EU-KI-Rechtsakt erkennt die Bedeutung der **Förderung** der KI-Kompetenz bei Bürgern, Unternehmen und Behörden an, um eine **sichere**, **ethische** und **effektive** Nutzung von KI-Technologien zu gewährleisten.

Exercise 3

1. Was ist mit ethischer KI-Nutzung gemeint?
2. Sammeln Sie Beispiele der sieben unverbindlichen ethischen Grundsätze, anhand z.B.: https://artificialintelligenceact.eu/de/recital/27/

5 min Breakouts

5 min Plenum

KI KOMPETENZ

KI-Kompetenz Ziele

- **KI-Kompetenz erhöht die Sicherheit von KI-Systemen** Durch Schulung und Weiterbildung können die Fähigkeiten im Umgang mit KI verbessert werden, was die Sicherheit erhöht.
- **KI-Kompetenz schärft das Bewusstsein für Ethik** Mit Wissen über KI steigt das Verständnis für mögliche Schäden und ethische Aspekte.
- **KI-Kompetenz schützt Nutzer** Wenn Nutzer KI besser verstehen, können sie Risiken besser einschätzen und Schäden vermeiden.

Die Stärkung der **KI-Kompetenz** ist entscheidend, um Einzelpersonen und Organisationen dabei zu unterstützen, die **KI-Landschaft verantwortungsvoll zu navigieren**.

Das EU-KI-Gesetz fördert die KI-Kompetenz, um KI sicherer, ethischer und für Nutzer schützenswerter zu machen. Dazu gehören Bildungsprogramme, Schulungsmaterialien und Sensibilisierungskampagnen für verschiedene Interessengruppen.

KI KOMPETENZ

Ausreichendes Maß an Kompetenz (Artikel 3 Nr. 56)

"KI-Kompetenz“ [bezeichnet] die Fähigkeiten, die Kenntnisse und das Verständnis, die es Anbietern, Betreibern und Betroffenen unter Berücksichtigung ihrer jeweiligen Rechte und Pflichten im Rahmen dieser Verordnung ermöglichen, KI-Systeme sachkundig einzusetzen sowie sich der Chancen und Risiken von KI und möglicher Schäden, die sie verursachen kann, bewusst zu werden."
Artikel 3 Nr.56

KI KOMPETENZ

Seit dem 2. Februar 2025 gelten die Regelungen für die KI-Kompetenz gemäß Artikel 4 der KI-Verordnung.

Zeit-Check 16:30? Skip

Wer?

Was?

Wie?

"Die Anbieter und Betreiber von KI-Systemen ergreifen Maßnahmen, um nach besten Kräften sicherzustellen, dass ihr Personal und andere Personen, die in ihrem Auftrag mit dem Betrieb und der Nutzung von KI-Systemen befasst sind, über ein ausreichendes Maß an KI-Kompetenz verfügen, wobei ihre technischen Kenntnisse, ihre Erfahrung, ihre Ausbildung und Schulung und der Kontext, in dem die KI-Systeme eingesetzt werden sollen, sowie die Personen oder Personengruppen, bei denen die KI-Systeme eingesetzt werden sollen, zu berücksichtigen sind." Artikel 4

KI KOMPETENZ

Was sieht die KI-Verordnung vor und was ist nicht vorgeschrieben?

Zur Einhaltung der Verpflichtung zur KI-Kompetenz sollten Organisationen beim Einsatz und bei der Nutzung von KI

- ein allgemeines Verständnis von KI sicherstellen,
- die Rolle der eigenen Organisation als Anbieter oder Betreiber beachten,
- die Risiken des spezifischen KI-Systems im konkreten Kontext berücksichtigen,
- aktuelle Entwicklung und Neuerungen einbeziehen.

Nicht vorgeschrieben für die Compliance mit Artikel 4 sind:

- formalisierte oder standardisierte Trainingsmaßnahmen,
- (externe) Zertifizierungen der durchgeführten Maßnahmen,
- die Einführung eines KI-Beauftragten und
- regelmäßige Vorabüberprüfungen der Maßnahmen zur Sicherstellung der KI-Kompetenz durch Aufsichtsbehörden.

Ein Mangel an KI-Kompetenz kann als Verletzung der Sorgfaltspflicht angesehen werden, insbesondere wenn dadurch ein Schaden entsteht. Daher empfiehlt die Bundesnetzagentur, dass Organisationen ihre Maßnahmen zur Sicherstellung von KI-Kompetenz gut **dokumentieren.** So können sie jederzeit nachweisen, dass sie die Anforderungen des Artikels 4 erfüllen.

KI KOMPETENZ

Wie baut man KI-Kompetenzen auf?

Die KI-Verordnung schreibt bewusst **keine spezifischen Formate** oder sonstige formalisierte und standardisierte Maßnahmen vor, da es schlicht keine „one-fits-all“ Lösung gibt.
Organisationen sollen die Möglichkeit haben, die Maßnahmen zur Bildung und zum Ausbau der KI-Kompetenz an **ihren Bedarf anzupassen**. Dieser Bedarf hängt u.a. von den eingesetzten KI-Systemen und den damit verbundenen Risiken sowie den Aufgaben und Vorkenntnissen des Personals ab.
So können Organisationen individuell entscheiden, wie sie ihre KI-Kompetenz sicherstellen. Diese Entscheidung soll **plausibel und nachvollziehbar** sein.

KI KOMPETENZ

KI- Kompetenz als Enabler

Zum Ausschöpfen des Potentials, welches KI unbestritten bietet, liegt eine hohe KI-Kompetenz der Mitarbeitenden bereits im Eigeninteresse und somit in der Eigenverantwortung von Organisationen.

Ein hohes Maß an KI-Kompetenz ermöglicht es Organisationen u.a.:

- **fundierte Entscheidungen zu treffen**
- **Arbeitsbedingungen zu verbessern und Innovation zu fördern**
- **die Einhaltung und Durchsetzung der Verordnung sicherzustellen**

KI KOMPETENZ

Vier Grundsteine zum Aufbau der KI-Kompetenz

1. Individuellen Bedarf ermitteln	**Welche Personen** entwickeln, betreiben oder nutzen KI-Systeme? **Welche KI-Systeme** sind das? **Zu welchem Zweck** arbeiten diese Personen mit diesen KI-Systemen? **Welche Risiken** sind mit der Arbeit mit diesen KI-Systemen verbunden?
2. Maßnahmen ausgestalten und hierbei beachten:	**Individuelle Faktoren** der betroffenen Personen wie Ausbildung, Erfahrung, Wissensstand, Art der Tätigkeit; den **Kontext**, in dem das jeweilige KI-System eingesetzt wird, z.B. Anwendungsbereich, Nutzungsphase, betroffene Personen, Zweck; das damit verbundene **Risiko** sowie die **Rolle der eigenen Organisation** hinsichtlich der KI-Wertschöpfungskette.
3. Regelmäßige Auffrischung	Der Aufbau von KI-Kompetenzen sollte ein dynamischer und kontinuierlicher Prozess sein, da z.B. • der **Begriff der KI-Kompetenz** sich im Laufe der Zeit ändern kann, • der **Kontext der Nutzung** sich bei Personen ändern kann und • **technologische Entwicklungen** neue Anwendungsfelder eröffnen können.
4. Ausreichende Dokumentation der durchgeführten Maßnahmen, u.a.	die **Art** der Maßnahmen, den inhaltlichen und zeitlichen **Umfang**, die teilnehmenden **Personen**.

Empfehlung:

Interdisziplinär, da so die technischen, rechtlichen und ethischen Aspekte der künstlichen Intelligenz und ihre Interaktion effektiv berücksichtigt werden.

Stufenweise, da die KI-Kompetenz sukzessiv in Abhängigkeit von unterschiedlichen Kenntnissen innerhalb der Belegschaft aufgebaut wird.

KI KOMPETENZ

Format und Inhalt der Maßnahmen

Stufe 1:
Schaffung eines grundlegenden Verständnisses von Daten und KI in der Organisation

Grundlagen von Daten und KI, u.a. Begriffe, Historie
Überblick über KI-Technologien, u.a. Maschinelles Lernen, große Sprachmodelle
Allgemeine Chancen und Risiken von KI, z.B. durch Anwendungsfälle

Stufe 2:
Aufbau fortgeschrittener KI-Kompetenzen

Rolle der Organisation in der KI-Wertschöpfungskette, z.B. Entwickler, Nutzer
Technische Aspekte der angewendeten KI
Spezifische Chancen und Risiken und rechtliche Einordnung der angewendeten KI

Stufe 3:
Rollenspezifische Trainings mit individuellen Schwerpunkten, z.B. Technik, Recht, Ethik

KI KOMPETENZ

Betroffene Personen

Relevante Artikel: Artikel 4, Erwägungsgrund 20

- Kompetenzförderungen für Personen, die mit Betrieb und Nutzung von KI-Systemen befasst sind

Developer	Subject Matter Experts	Support-Mitarbeiter	Management

Minimales bzw. kein Risiko

EU AI ACT

Risikostufen KI- Systeme: Minimales bzw. Kein- Risiko -KI-Systeme

Inakzeptables Risiko

- **Verboten**
- sie verstoßen gegen EU-Grundrechte
- Beispiel: Social Scoring,
  Echtzeit-Überwachung - Gesichtserkennung in öffentlichen Räumen zur Strafverfolgung ohne gerechtfertigten Anlass

Hohes Risiko

- **Nur mit Konformitätsbewertung erlaubt**
- hohes Risiko für Gesundheit, Sicherheit oder Grundrechte
- Beispiel: Funkanlagen, Spielzeug, Medizinprodukte

Begrenztes Risiko

- **Transparenzpflichten**
- Beispiel: Chatbots, Deepfake,
  KI-Systeme zur Erstellung von Text, Bild, Audio

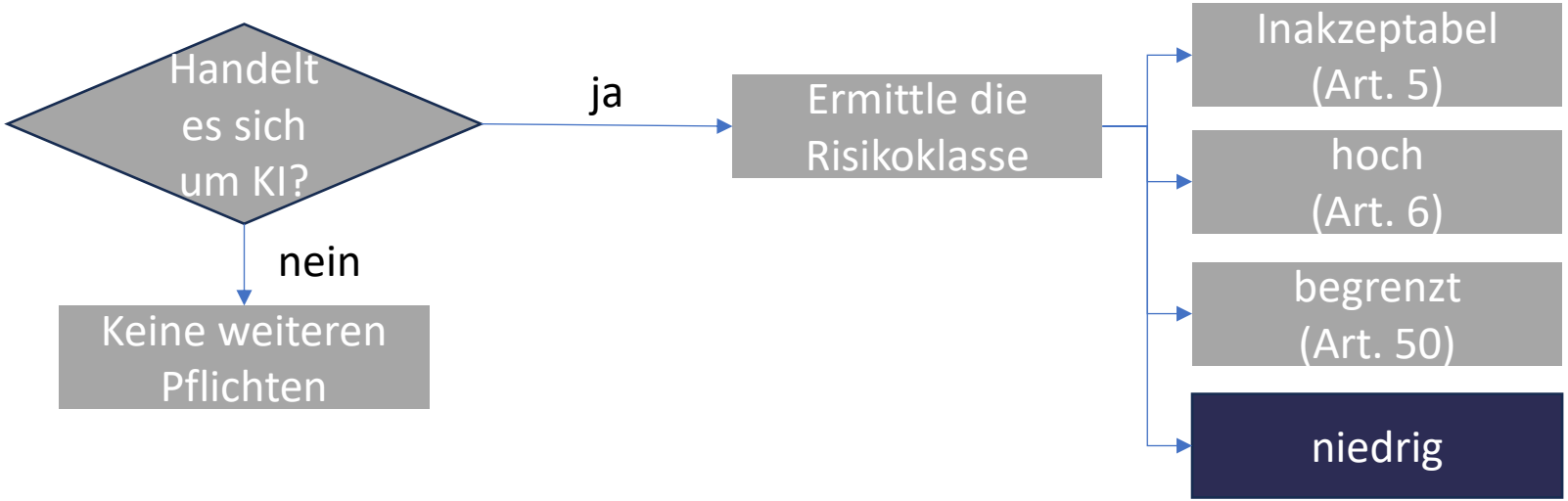
Minimales bzw. kein Risiko

- **Keine besonderen Verpflichtungen**
- freiwillige Verhaltenskodizes sind möglich
- Beispiel: Video-Spiele, Spam-Filter

Freiwillige Kodizes bei minimalem Risiko

EU AI ACT

Risikoklasse: hoch



EU AI ACT

Minimales bzw. kein Risiko

Keine besonderen Verpflichtungen, freiwillige Verhaltenskodizes sind möglich
KI-Systeme mit minimalem Risiko, wie beispielsweise Spam-Filter, sind weitgehend unreguliert, da sie keine signifikanten Risiken für die Gesellschaft oder Einzelpersonen darstellen. Auf freiwilliger Basis wird dennoch empfohlen, dass solche Systeme gewissen Prinzipien für vertrauenswürdige KI folgen, z. B. hinsichtlich Fairness und Transparenz.

Beispiele:

- Spamfilter, Videospiele, Bestandsverwaltung
- Keine Anwendung der KI- VO

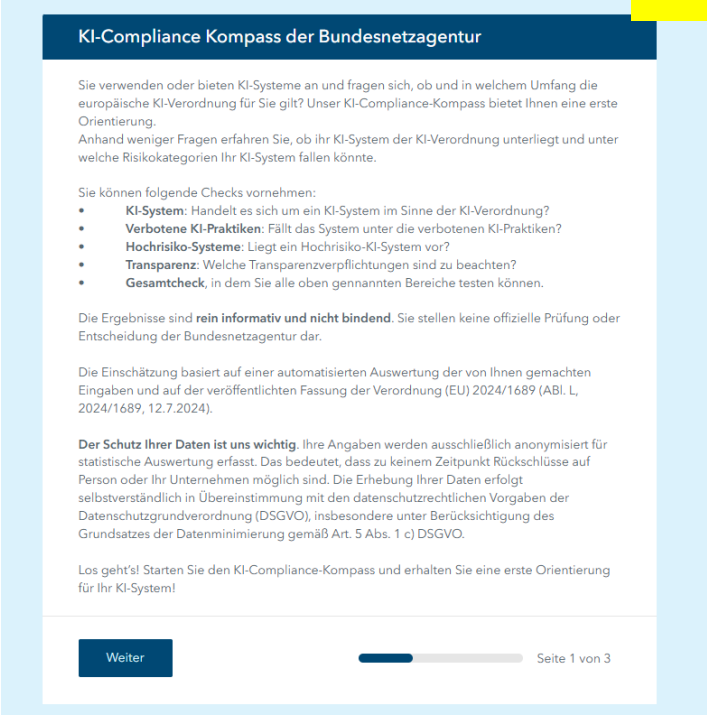
Compliance in der Praxis

gollnickdata.de

EU AI ACT – RISIKO KOMPASS

Tipp

1. **Risikobasierter Ansatz**
2. Checkliste



KI-Compliance Kompass der Bundesnetzagentur

Sie verwenden oder bieten KI-Systeme an und fragen sich, ob und in welchem Umfang die europäische KI-Verordnung für Sie gilt? Unser KI-Compliance-Kompass bietet Ihnen eine erste Orientierung.
Anhand weniger Fragen erfahren Sie, ob ihr KI-System der KI-Verordnung unterliegt und unter welche Risikokategorien Ihr KI-System fallen könnte.

Sie können folgende Checks vornehmen:

- **KI-System**: Handelt es sich um ein KI-System im Sinne der KI-Verordnung?
- **Verbotene KI-Praktiken**: Fällt das System unter die verbotenen KI-Praktiken?
- **Hochrisiko-Systeme**: Liegt ein Hochrisiko-KI-System vor?
- **Transparenz**: Welche Transparenzverpflichtungen sind zu beachten?
- **Gesamtcheck**, in dem Sie alle oben gennannten Bereiche testen können.

Die Ergebnisse sind **rein informativ und nicht bindend**. Sie stellen keine offizielle Prüfung oder Entscheidung der Bundesnetzagentur dar.

Die Einschätzung basiert auf einer automatisierten Auswertung der von Ihnen gemachten Eingaben und auf der veröffentlichten Fassung der Verordnung (EU) 2024/1689 (ABl. L, 2024/1689, 12.7.2024).

Der Schutz Ihrer Daten ist uns wichtig. Ihre Angaben werden ausschließlich anonymisiert für statistische Auswertung erfasst. Das bedeutet, dass zu keinem Zeitpunkt Rückschlüsse auf Person oder Ihr Unternehmen möglich sind. Die Erhebung Ihrer Daten erfolgt selbstverständlich in Übereinstimmung mit den datenschutzrechtlichen Vorgaben der Datenschutzgrundverordnung (DSGVO), insbesondere unter Berücksichtigung des Grundsatzes der Datenminimierung gemäß Art. 5 Abs. 1 c) DSGVO.

Los geht's! Starten Sie den KI-Compliance-Kompass und erhalten Sie eine erste Orientierung für Ihr KI-System!

Weiter

Seite 1 von 3

https://www.bundesnetzagentur.de/DE/Fachthemen/Digitales/KI/2_Risiko/kompass/start.html

CHECKLISTE FÜR BETREIBER VON BEGRENZTES RISIKO

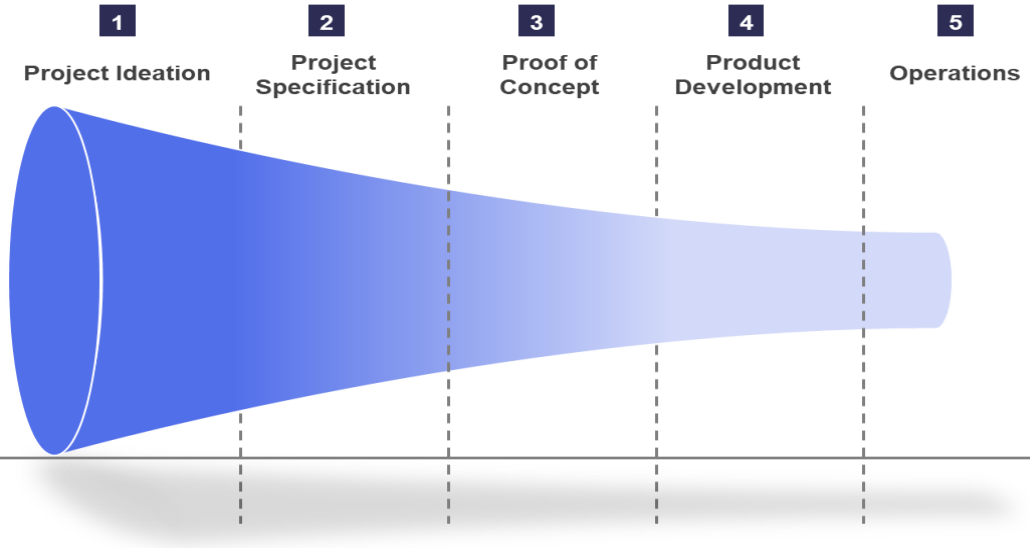
Tipp

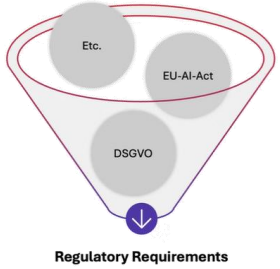
1. Risikobasierter Ansatz
2. **Checkliste**

- 1. Überblick über KI-Systeme im Unternehmen & Verwendungszweck verschaffen
- 2. Kategorisierung und Risikobewertung von KI-Systemen
- 3. Bewertung der Verantwortlichkeit
- 4. KI-Kompetenzen vermitteln
- 5. Transparenz- & Informationspflichten prüfen
- 6. Notfall- und Eskalationsprozesse
- 7. Kontinuierliche Überprüfung und Anpassung

https://www.ihk-muenchen.de/ratgeber/digitalisierung/kuenstliche-intelligenz/ai-act/#st_accordion_tabs

Compliance by design in Practice





Compliance by design: Aufgaben und Artefacte auf einzelne Phasen mappen!

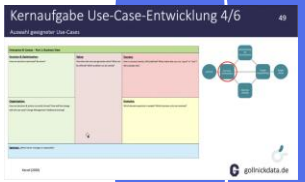
Rechtl. / Regulatorische Anforderungen nicht erst am Ende, sondern von der ersten Idee fest in den Entwicklungszyklus einweben als integralen Bestandteil der Produkt DNA, wodurch Nachbesserungen, Verzögerungen, Scheitern vermieden warden.

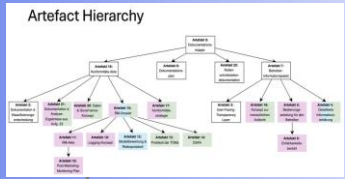
Deep Dive on Wednesday!

Compliance by design in Practice

Deep Dive on Wednesday!

1	2	3	4	5
Project Ideation	**Project Specification**	**Proof of Concept**	**Product Development**	**Operations**





Risikoanalyse: Frühzeitige Einstufung der KI nach dem EU AI Act (verboten, hoch, gering). Rechtliche Durchführbarkeit.

Zweckbestimmung & DSGVO by Design: Datensparsamkeit, Anonymisierung, Pseud. Bereits bei Datenbeschaffung

EU-AI-Act integriert: Bias-Monitoring, Data Lineage, Explainability, Fairness + Dokumentation.

Testing & Validation: Compliance Tests in CI/CD Pipeline, human-in-the-loop mechanism

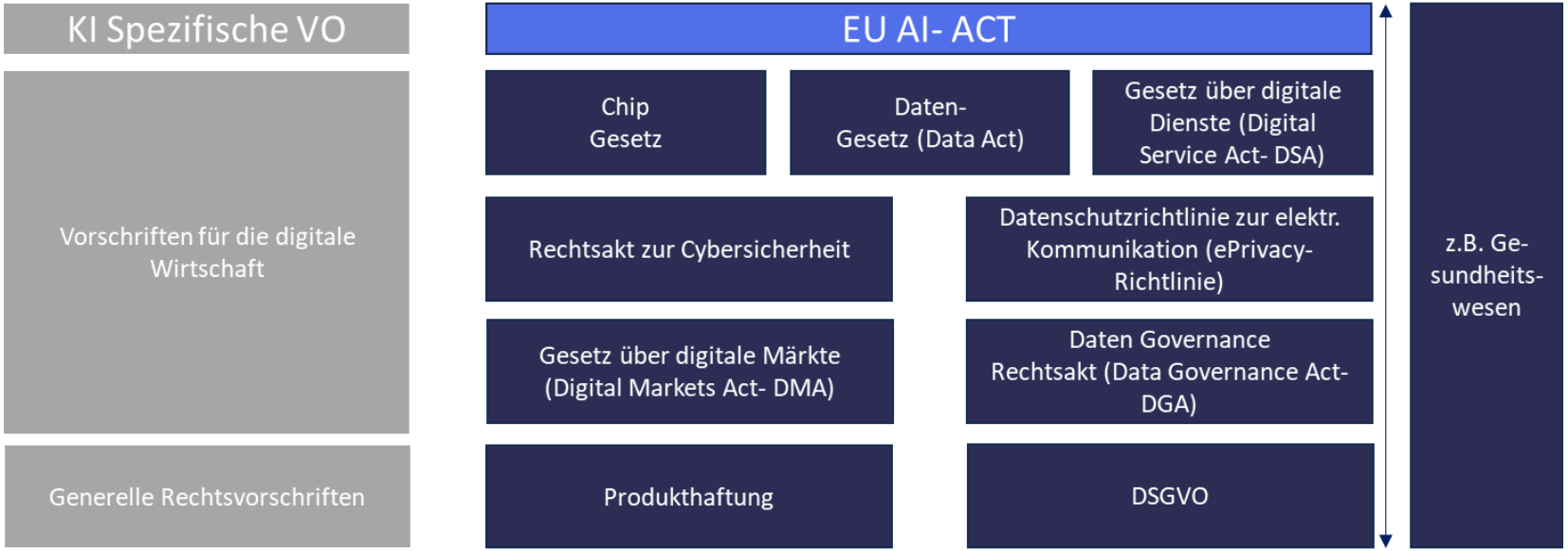
Monitoring: Laufende Überwachung der Modellleistung (Drift) und Verhaltens, autom. Logging.

Aktueller Ausblick

gollnickdata.de

STAND JETZT: KOMPLIZIERTES REGELWERK

EU Rechtsrahmen: Fazit zum regulatorischen Flickenteppich



Ein regulatorischer **Flickenteppich innerhalb der EU**

KOMMT JETZT DER OMNIBUS?

Europäische Kommission

DE | Search

Gestaltung der digitalen Zukunft Europas

Home | Politikbereiche | Aktivitäten | Nachrichten | Bibliothek | Finanzierung | Kalender | Konsultationen | AI Office

Home > Bibliothek > Vorschlag für eine digitale Omnibus-Verordnung über KI

POLICY AND LEGISLATION | Veröffentlichung 19 November 2025

Vorschlag für eine digitale Omnibus-Verordnung über KI

Die Kommission schlägt gezielte Vereinfachungsmaßnahmen vor, um eine rechtzeitige, reibungslose und verhältnismäßige Umsetzung bestimmter Bestimmungen des KI-Gesetzes zu gewährleisten.

Um diesen Herausforderungen zu begegnen, schlägt die Kommission gezielte Vereinfachungsmaßnahmen vor, um eine rechtzeitige, reibungslose und verhältnismäßige Umsetzung bestimmter Bestimmungen des KI-Gesetzes sicherzustellen.

Zugang zum Vorschlag und seinen Anhängen in allen EU-Amtssprachen

DIGITAL OMNIBUS PACKAGE

See also

Mehr zu einem agilen digitalen Regelwerk für die EU

https://digital-strategy.ec.europa.eu/de/library/digital-omnibus-ai-regulation-proposal

Aktuelle Meinungen

PRESSEMITTEILUNG:

Digital Omnibus stärkt europäische
KI-Unternehmen: Fristverlängerung ur
Vereinfachungen bringen dringend ben
Entlastung

Der KI Bundesverband sieht im heute vorgestellten Entwurf des Digit
ersten Schritt zur notwendigen Simplifizierung der europäischen Digitalge
begrüßt die Vorschläge der Europäischen Kommission.

Dr. Robert Kilian, Vorstandsmitglied KI Bundesverband: *"Das ist ein klä*
die europäische KI-Landschaft und Wettbewerbsfähigkeit. In der Veröffen

https://ki-verband.de/digital-omnibus/

NETZPOLITIK.ORG

Digitaler Omnibus

„Größter Rückschritt für digitale Grund
Geschichte der EU"

NETZPOLITIK.ORG

Stalkerware, Datenhändler, Rechtsradikale - wir recherchieren mit Deiner Unterstütz

KI und Datenschutz

Wo der Digitale Omnibus der EU gerade hinro

Unter Hochdruck will die EU Teile ihrer Digitalregulierung überarbeiten. Währen
letzten Metern noch um ein Verbot sexualisierter Deepfakes ergänzt werden kön
Datenomnibus zwei wichtige EU-Institutionen auf die Bremse. Die neuesten Entw
Überblick.

18.02.2026 um 16:14 Uhr - Anna Ströbele Romero, Ingo Dachwitz - in Datenschutz - e

https://netzpolitik.org/2026/ki-und-datenschutz-wo-der-digitale-omnibus-der-eu-gerade-hinrollt/

Menü

Handelsblatt

Anmelden Abo

Auflagen

EU schwächt KI-Regulierung ab – Längere Übergangsfristen

Ein Gesetzentwurf sieht unter anderem vor, dass Unternehmen künftig ihre KI mit den persönlichen Daten europäischer Nutzer trainieren dürfen sollen. Das wird aus zwei Richtungen kritisiert.

19.11.2025 - 15:20 Uhr

Artikel anhören 02:59

https://www.handelsblatt.com/politik/intern... ...schwaecht-ki-regulierung-ab-laengere-uebergangsfristen/100176269.html

...Media Deutschland
info@buendnis-f5.de

Zweite Kommentierung Digitales Omnibuspaket der EU Kommission

Übersicht

Der Digitale Omnibus verfolgt laut der Europäischen Kommission das Ziel, bestehende digitale Regelwerke zu vereinfachen und ihre Anwendung zu harmonisieren. Die vorgeschlagenen Änderungen an der DSGVO, KI-VO, und den Datenrechtsakten erreichen dieses Ziel jedoch nur vereinzelt. In vielen Punkten bringt die Kommission umfassende Änderungsvorschläge ein, die auch grundrechtliche Schutzstandards betreffen.

In dieser Kommentierung betrachten wir 14 wichtige Punkte der Gesetzespakete. Das Dokument ist nicht als vollständige Kommentierung aller Vorschläge gedacht, sondern fasst unsere Einschätzungen und Analysen zu zentralen Aspekten zusammen. Jede Seltion umfasst zudem Änderungsvorschläge

https://www.reporter-ohne-grenzen.de/artikel/pressemitteilungen/4201/kritik-am-digitalen-omnibuspaket-der-eu-kommission

KI-Compliance: Take-aways

- Compliance = aktives Riskomanagement!
- Die Rolle bestimmt die Haftung
- Framework für Vorschriften-Dschungel
- Transparenz ist die Währung des Vertrauens
- *Compliance by Design* spart Kosten